

第五章 访问控制课后作业（1）

一、填空题

- 1、访问控制是对主体访问客体的能力或权力的限制，它包括主体、客体、引用监控器和访问控制策略四个要素。
- 2、基于所有权的访问控制分为：自主访问控制和强制访问控制。
- 3、访问控制的二元组描述方法通常包含访问控制矩阵、访问控制列表、访问能力表和授权关系表四种形式。

二、选择题

- 1、访问控制是指确定（ A ）以及实施访问权限的过程。
A. 用户权限； B. 可给予哪些主体访问权利；
C. 可被用户访问的资源； D. 系统是否遭受入侵
- 2、下列关于访问控制主体和客体的说法中，错误的是（ BD ）
A.主体是一个主动的实体，它提供对客体中的对象或数据的访问要求；
B.主体可以是访问信息的用户、程序和进程；
C.客体是含有被访问信息的被动实体；
D.一个对象或数据如果是主体，则其不可能是客体
- 3、以下对访问控制列表和访问能力表说法正确的是（D）
A.访问能力表表示每个客体可以被访问的主体及其权限；
B.访问控制列表说明了每个主体可以访问的客体及其权限；
C.访问控制列表一般随主体一起保存；
D.访问能力表更容易实现访问权限的传递，但回收访问权限较困难。
- 4、下图为访问控制列表。以下说法正确的是（D）

主体	客体			
	File1	File2	File3	File4
N1	Own,R,W,E		Own,R,W,E	
N2	R	Own,R,W,E	W	R
N3	R,W	R		Own,R,W,E

- A.N1 是管理员； B.N2 是管理员； C.N3 是管理员； D.都不是管理员

5、访问控制策略的制定必须体现主体、客体和访问规则集等三者之间的关系，需要遵循以下原则（BCD）

A.保密性原则； B. 最小特权原则； C.最小泄漏原则； D.多级安全原则

三、简答题

1、学校教务系统中，学生只有提交了评教，才能看到分数，这是“访问控制”吗？为什么？

答：是的。

访问控制是对主体访问客体的能力或权力的限制；

这样的访问控制策略定义了主体对客体的动作、行为。

2、名称解释：自主访问控制，强制访问控制。

答：

自主访问控制：资源（客体）的所有者（主体）即为该客体的属主，每个客体有且仅有一个属主。属主能够根据自己的意愿将该资源的访问权限子集直接或间接地分发给其他主体，或从其他主体手绘，不受任何安全策略地限制，即在自主访问控制之下；

强制访问控制：强制访问控制与自主访问控制相比，具有更为严格的访问控制策略，普通用户不再具有资源的管理权限。系统（如系统管理员）为每个主体（或进程、用户）和客体（资源）赋予一定的安全属性，任何主体不能改变自身、任何主体或任何客体的安全属性，即只有系统管理员才能确定用户或用户组的访问权限。当一个主体访问一个客体（如资源）时，强制访问控制机制首先比较主体的安全属性和客体的安全属性，如果系统判定该主体没有权限访问这个客体，那么即使是该客体的属主也无权访问该客体。同时，系统管理员修改、授予、删除主体对客体的访问权限时，也要收到系统严格的审计和监控。

3、访问控制策略制定遵循的基本原则是什么？举例说明。

答：访问控制策略制定遵循的基本原则是：最小特权原则、最小泄露原则、多级安全原则；

如：

- 1、东南大学信息门户不同的账户具有不同的权限，学生可以查看成绩，提交评教结果，而不能修改成绩；教师可以增删查改学生的成绩，而不能修改评教结果，也不能修改或查看学生的学籍，这是最小特权原则；
- 2、同学们只能在信息门户上查看自己的成绩，而不能查看其他人的成绩，这是最小泄露原则
- 3、东南大学信息门户下的不同一卡通账户具有不同的安全等级，这是主体划分的安全等级，教务处老师的账号安全等级比普通大学老师账号的安全等级更高，大学老师们账号的安全等级比学生账号更高；校内资源作为客体也具有不同的安全等级，实验室计算机里的数据安全等级比图书馆藏书的安全等级高，图书馆书籍的安全等级比学校公众号的安全等级高。以上可以体现多级安全原则